

## FIXNET

# Authentication & Authorization Design

*Technical Design Document — Identity, Access Control & Security Policy*

**Document Version:** 1.0

**Status:** Draft for Review

**Date:** August 24, 2026

**Related Document:** FIXNET API Design Specification (companion document)

## 1. Overview

---

FIXNET supports two distinct user populations with different risk profiles and usability requirements. Customers and technicians use the mobile app and authenticate via passwordless SMS OTP for speed and low friction in low-connectivity environments. Administrative staff (support agents, finance admins, and system admins) access a browser-based Admin Portal that handles sensitive financial and personal data, and therefore requires a stronger credential-plus-MFA flow. This document defines both authentication flows, the token architecture shared across them, the security middleware enforced on every request, and the role-based access control (RBAC) matrix that governs authorization across the platform.

## 2. Authentication Flows

---

FIXNET uses two distinct authentication mechanisms depending on the portal being accessed:

- **Customer & Technician Apps:** SMS OTP-based passwordless login.
- **Admin Portal:** Email + password + mandatory TOTP multi-factor authentication (MFA).

### 2.1 Flow A — Mobile OTP Authentication (Customers & Technicians)

This flow removes the need for passwords entirely for the mobile user base, reducing support overhead and improving accessibility.

#### Step 1 — Request OTP

- User inputs a phone number in E.164 format (e.g., +25078XXXXXXX).
- The system generates a 6-digit cryptographically secure numeric code, valid for 5 minutes.
- The code is hashed and stored in Redis with rate-limit counters attached.

- The code is dispatched via Africa's Talking or Twilio SMS gateway.

### Step 2 — Verify OTP

- User submits their phone number together with the 6-digit code.
- The server validates the code against the hashed value in Redis, checking expiry and attempt count.

### Step 3 — Token Issuance

- On successful verification, the API returns a short-lived JWT Access Token (15 minutes) and a long-lived Refresh Token (30 days).

## 2.2 Flow B — Admin Portal Login

Administrative access carries higher risk (financial reports, refunds, user suspension) and is protected by a two-factor sequence.

### Step 1 — Credentials Check

- Admin enters email and password.
- Password is verified using bcrypt with a work factor of 12 or greater.

### Step 2 — MFA Challenge

- If credentials match, the server returns an interim mfa\_token, valid for 3 minutes.

### Step 3 — TOTP Verification

- Admin submits the 6-digit TOTP code from their authenticator app.
- On success, full JWT Access and Refresh tokens are issued, identical in structure to the mobile flow.

## 3. Token Architecture & Management

### 3.1 Access Token

|                     |                                                                               |
|---------------------|-------------------------------------------------------------------------------|
| <b>Format</b>       | Bearer JWT, passed in the Authorization header: Authorization: Bearer <token> |
| <b>Lifespan</b>     | 15 minutes                                                                    |
| <b>Issuer (iss)</b> | fixnet-auth-service                                                           |

Example payload structure:

```
{
  "sub": "usr_9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
  "role": "technician",
  "phone_number": "+250788123456",
  "language": "rw",
  "iat": 1787400000,
```

```
"exp": 1787400900,
"iss": "fixnet-auth-service"
}
```

### 3.2 Refresh Token

|                        |                                                                                                          |
|------------------------|----------------------------------------------------------------------------------------------------------|
| <b>Format</b>          | Cryptographically random opaque string                                                                   |
| <b>Client Storage</b>  | SecureStorage in the Flutter mobile app; HttpOnly Cookie in the React Admin Portal                       |
| <b>Lifespan</b>        | 30 days                                                                                                  |
| <b>Rotation Policy</b> | Every call to /auth/token/refresh invalidates the old refresh token and issues a new access/refresh pair |

#### Why rotate on every refresh?

Rotation ensures a stolen refresh token has a limited window of use — once the legitimate client refreshes, the old token is dead, so reuse of a leaked token is detectable and self-limiting.

## 4. Security Policies & Middleware Rules

### 4.1 Rate Limiting — REQ-SEC-005

The OTP request and verify endpoints are strictly limited to 10 requests per minute, enforced per IP address and per phone number independently.

### 4.2 Brute-Force Lockout — REQ-ACC-003

Entering 5 incorrect OTPs within a 15-minute window triggers a 30-minute lock on that phone number. Each attempt logs device metadata (IP, user agent, device fingerprint if available) to support fraud investigation.

### 4.3 Presigned URLs — REQ-SEC-002

Technician identity documents are stored in private S3 buckets and are never publicly addressable. Access is granted only via temporary pre-signed URLs with a maximum expiration of 15 minutes.

### 4.4 Data Encryption — REQ-SEC-001

- In transit: TLS 1.3 enforced on all API traffic.
- At rest: AES-256 encryption for stored data, including database volumes and object storage.

## 5. Role-Based Access Control (RBAC) Matrix

FIXNET defines five roles: customer, technician, support\_agent, finance\_admin, and system\_admin. Access to each functional area is enforced at the API gateway / middleware layer, independent of the underlying business logic. The matrix below summarizes access per functional endpoint group.

| Endpoint Group                               | Customer | Technician | Support Agent | Finance Admin | System Admin |
|----------------------------------------------|----------|------------|---------------|---------------|--------------|
| Customer Discovery & Chat                    | ✓ Full   | ✗ None     | 🕒 Read-only   | ✗ None        | 🕒 Read-only  |
| Quotes & Service Execution                   | ✓ Accept | ✓ Create   | 🕒 Read-only   | ✗ None        | 🕒 Read-only  |
| Deposit Payments                             | ✓ Full   | ✗ None     | 🕒 Read-only   | 🕒 Read-only   | 🕒 Read-only  |
| Technician Verification & Content Moderation | ✗ None   | ✗ None     | ✓ Full        | ✗ None        | ✓ Full       |
| Disputes & Refunds                           | ✗ None   | ✗ None     | ✓ Full        | ✓ Full        | ✓ Full       |
| Global Pricing & Config                      | ✗ None   | ✗ None     | ✗ None        | ✗ None        | ✓ Full       |
| Financial CSV Reports                        | ✗ None   | ✗ None     | ✗ None        | ✓ Full        | ✓ Full       |
| User Suspension & Audits                     | ✗ None   | ✗ None     | ✗ None        | ✗ None        | ✓ Full       |

Legend: ✓ = full access, ✓ (Accept/Create) = scoped write access, 🕒 = read-only, ✗ = no access.

## 5.1 Notable Authorization Rules

- **Financial separation of duties:** finance\_admin can process refunds and generate financial reports but cannot moderate content or verify technicians; system\_admin has full access across all domains.
- **Support agent scope:** support\_agent can moderate content and resolve disputes/refunds but has read-only visibility into customer discovery and chat, and no access to global pricing configuration.
- **Customer/technician isolation:** Customers and technicians never see each other's administrative surfaces — both are restricted to their own transactional endpoints (chat, quotes, deposits for customers; quote creation for technicians).

## 6. Open Questions for Review

- Should the 15-minute Access / 30-day Refresh token policy or the OTP/lockout rate limits be adjusted for any specific role?
- Do we need device-level session management (e.g., 'log out of all devices') for the Admin Portal?
- Should technicians have a distinct, shorter refresh token lifespan given the sensitivity of their earnings and ID data?